

Information Security Management System for GreenGrid Energy

Master's in Computer Engineering - Cybersecurity and Systems
Administration
Security Management Systems (SIGSEG)

ISEP INSTITUTO SUPERIOR
DE ENGENHARIA DO PORTO

Students:

1200720@isep.ipp.pt

1201346@isep.ipp.pt

1200920@isep.ipp.pt

Contents

1	GreenGrid Energy: Organizational Overview	1
1.1	Introduction	1
1.1.1	Project Team Structure and Individual Responsibilities	1
1.1.2	Collective Responsibilities	2
1.1.3	Forward-Looking Objectives	2
1.2	Governance and Leadership	3
1.3	Key Departments	4
1.3.1	Engineering & Grid Operations	4
1.3.2	Research & Development Department	5
1.3.3	Customer Services & Billing	6
1.3.4	Supply Chain Management Department	6
1.3.5	Human Resources (HR)	7
1.3.6	Legal & Administration	7
1.4	Infrastructure and Security Context	8
1.4.1	Core Technologies and Systems	8
1.4.2	Network Topology	8
1.4.3	Threat Landscape	8
1.4.4	Technology and Department Association	9
2	ISMS Scope	10
2.1	Organizational Stakeholders	10
2.2	Shared IT Infrastructure and Systems	11
2.3	Business Processes, Data, and Security Risks by Department	11
2.3.1	Engineering & Operations	11
2.3.2	Research & Development (R&D)	12
2.3.3	Customer Services	15
2.3.4	Finance	15
2.3.5	Supply Chain Management	15
2.3.6	Human Resources	17
2.3.7	IT Department	17
2.3.8	Sales and Marketing	17
2.4	ISMS Boundaries and Exclusions	17
3	Information Security Policy and Objectives	19
3.1	Stakeholder Requirements and Business Goals	19
3.2	Leadership Commitment	20
3.3	Monitoring and Review of ISMS Performance	20
3.4	Risk Management Goals and Compliance Requirements	20
3.5	Information Security Policy (Clause 4.2)	21

3.6	Department-Specific Security Objectives (Clause 6.2)	21
3.6.1	Engineering & Operations	21
3.6.2	Supply Chain Management	22
3.6.3	Research & Development (RD)	23
4	Other Security Policies and Procedures	25
4.1	Other Security Policies	25
4.1.1	Access Control Policy	25
4.1.2	Data Classification Policy	25
4.1.3	Incident Response Policy	26
4.1.4	Responsible IT Resource Usage Policy	26
4.2	Other Security Procedures	27
4.2.1	Access Control Procedure	27
4.2.2	Data Classification Procedure	27
4.2.3	Incident Response Procedure	28
4.2.4	Responsible Information Technology (IT) Resource Usage Procedure	28
5	Risk Management Framework	29
5.1	Risk Assessment Policy	29
5.2	Risk Assessment Process	29
5.2.1	Risk Identification	30
5.2.2	Risk Analysis	30
5.2.3	Risk Assessment	31
5.3	Risk Treatment Process	31
6	Risk Assessment Report	33
6.1	Shared assets	33
6.2	Research & Development (RD) Department	34
6.2.1	Asset Inventory	34
6.2.2	Risk Identification	34
6.2.3	Risk Analysis	35
6.2.4	Risk Assessment and Treatment	35
6.2.5	Implementation and Monitoring	35
6.3	Supply-chain assets	36
7	Statement of Application	37
7.1	Shared Assets	37
7.2	RD Department	38
7.2.1	Control Mapping and Justification	38
7.3	Supply-Chain Assets	39
A	Asset Inventory	41

List of Figures

1.1	Organizational chart of GreenGrid Energy	3
1.2	Organizational chart of Supply Chain Management Department	7
5.1	Risk level matrix used by GreenGrid Energy ²	30

Acronyms

ACL	Access Control List
AD	Active Directory
APTs	Advanced Persistent Threats
AWS	Amazon Web Services
CFO	Chief Financial Officer
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CIA	Confidentiality, Integrity, and Availability
CIS	Center for Internet Security
COO	Chief Operating Officer
CRM	Customer Relationship Management
CSF	Cybersecurity Framework
CTO	Chief Technology Officer
DER	Distributed Energy Resources
EISP	Enterprise Information Security Policy
ERP	Enterprise Resource Planning
EU	European Union
HR	Human Resources
IaaS	Infrastructure as a Service
IEC	International Electrotechnical Commission
ICS	Incident Command System
IDS	Intrusion Detection System
IoT	Internet of Things

IRP	Incident Response Plan
ISO	International Organization for Standardization
ISMS	Information Security Management System
ISSP	Issue-Specific Security Policy
IT	Information Technology
LAN	Local Area Network
MFA	Multi-factor Authentication
MSAs	Master Service Agreements
NIST	National Institute of Standards and Technology
NIS2	Network and Information Systems Directive II
OT	Operational Technology
PaaS	Platform as a Service
PII	Personally Identifiable Information
RFPs	Requests for Proposals
RFQs	Requests for Quotes
RBAC	Role Based Access Control
RD	Research & Development
SAP	Systems Applications and Products
SCADA	Supervisory Control and Data Acquisition
SIEM	Security Information and Event Management
SLA	Service-Level Agreement
SOC	Security Operations Center
SOWs	Statements Of Work
SysSP	System-Specific Security Policy
SoA	Statement of Applicability
TVA	Threat-Vulnerability-Asset
VPN	Virtual Private Network
SCM	Supply Chain Management
API	Application Programming Interface

Chapter 1

GreenGrid Energy: Organizational Overview

1.1 Introduction

GreenGrid Energy is a large-scale enterprise⁵ specialized in renewable energy, with particular expertise in smart grid technology. The company employs approximately 400 professionals and has achieved revenues of around 35 million euros in the latest fiscal year. Its business activities are structured around three core revenue streams:

1. Smart grid infrastructure deployment (45%),
2. Renewable energy supply contracts (40%),
3. Energy monitoring and analytics software (15%).

With the expanding adoption of renewable energy solutions and increasing integration of Internet of Things (IoT) devices, GreenGrid Energy operates at the intersection of Operational Technology (OT) and IT. This convergence necessitates a comprehensive cybersecurity approach, robust governance frameworks, and specialized departmental oversight.

To effectively respond to these challenges, GreenGrid Energy has assembled a dedicated project team to assess and strengthen information security practices within critical departments, while collaboratively addressing overall cybersecurity objectives.

1.1.1 Project Team Structure and Individual Responsibilities

The project team is composed of three specialists, each focusing on securing a critical area of operation:

Research & Development

Inês Ribeiro (1201346@isep.ipp.pt) assesses and enhances security practices within the RD department, safeguarding proprietary technologies, algorithms, and intellectual property. She ensures secure collaborative environments for technology pilot programs, mitigating risks from industrial espionage and cyber threats.

Supply Chain Management

Manuela Leite (1200720@isep.ipp.pt) is responsible for analyzing procurement processes, supplier security standards, and component lifecycle management. Her primary focus includes establishing guidelines to mitigate risks associated with third-party vendors, particularly regarding hardware integrity and supply-chain vulnerabilities.

Engineering & Operations

Eduardo Sousa (1200920@isep.ipp.pt) oversees the security and resilience of critical grid infrastructure, ensuring Supervisory Control and Data Acquisition (SCADA) systems, OT networks, and renewable energy integrations are safeguarded against cyber threats. His role includes maintaining compliance with industry regulations, implementing advanced monitoring solutions, and coordinating Incident Response Plan (IRP)s to minimize operational disruptions.

1.1.2 Collective Responsibilities

Beyond their individual roles, the team collaborates on key areas that affect multiple departments, including:

- **Engineering & Grid Operations:** Ensuring secure integration of emerging technologies, particularly within OT and IT networks, to maintain operational integrity.
- **HR:** Implementing Role Based Access Control (RBAC) and promoting a security-aware culture through employee training and awareness programs.
- **Legal & Administration:** Aligning departmental activities with legal and regulatory requirements, managing compliance frameworks, and streamlining incident reporting mechanisms.
- **Cybersecurity Strategy Development:** Creating comprehensive security policies, IRPs, and risk mitigation frameworks applicable organization-wide.

1.1.3 Forward-Looking Objectives

The project team's strategic objectives include:

1. Conducting comprehensive risk assessments to identify critical assets, vulnerabilities, and potential impacts across departments.
2. Implementing an Information Security Management System (ISMS) aligned with recognized international frameworks (such as ISO 27001 or National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF)).
3. Ensuring secure convergence and seamless integration between OT and IT infrastructures.
4. Fostering a proactive security culture emphasizing continuous improvement and awareness throughout the organization.

1.2 Governance and Leadership

GreenGrid Energy follows a governance model that balances strategic oversight with efficient operations:

- **Board of Directors:** Define strategic vision, approves major investments, and ensures compliance with energy sector regulations.
- **CEO! (CEO!):** Oversees day-to-day operations and reports directly to the Board.
- **Executive Management Team:**
 - *Chief Financial Officer (CFO):* Handles budget planning, financial compliance, and resource allocation.
 - *Chief Technology Officer (CTO):* Determines technological direction, including research initiatives and product development.
 - *Chief Operating Officer (COO):* Manages core operations, covering engineering, supply chain, and service delivery.
 - *Chief Information Officer (CIO):* Aligns IT strategy with business objectives and oversees IT infrastructure.
 - *Chief Information Security Officer (CISO):* Develops cybersecurity strategies and enforces best practices across OT and IT domains.
- **Department Directors or Managers:** Lead their respective divisions and report to the relevant C-level executive.

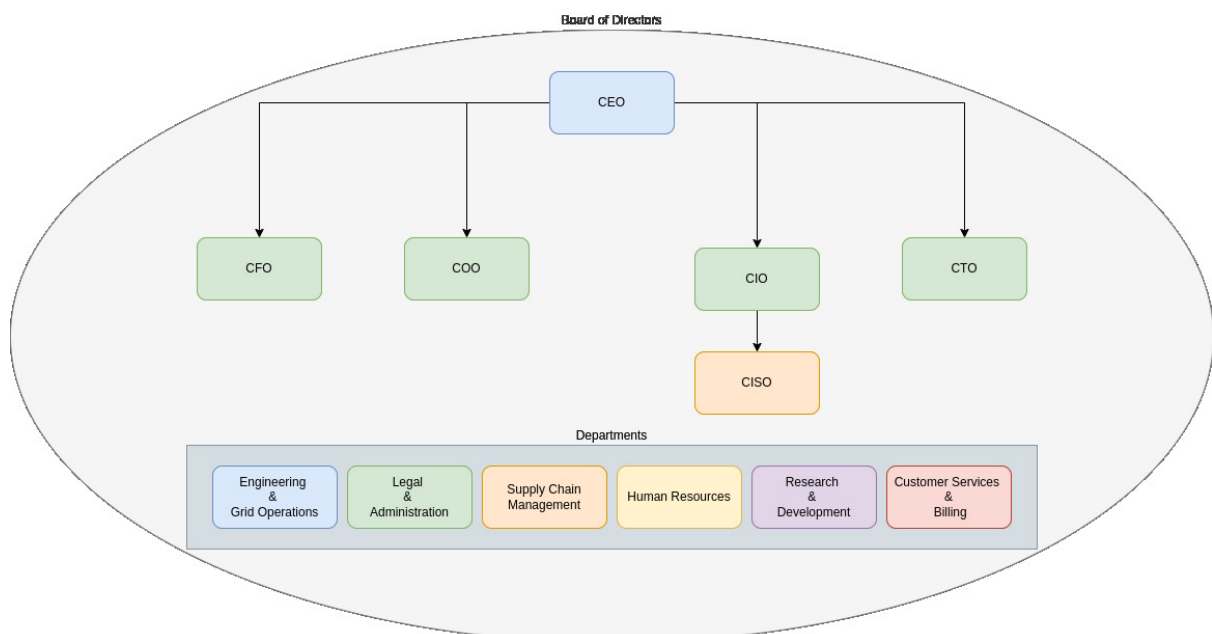


Figure 1.1: Organizational chart of GreenGrid Energy

Figure 1.1 provides an overview of the organization's structure. Each department has a dedicated director, while the executive team members focus on their respective areas of expertise. Together with the **CEO!** and department directors, these executives form the

Board of Directors. All major decisions—including governance matters and the scope of new or revised policies—must be approved by this governing body before implementation throughout the company and its individual departments.

1.3 Key Departments

GreenGrid Energy employs a total of 400 staff members. Of these, 12 serve in leadership roles across the Board of Directors and C-level positions, leaving 388 employees distributed among the following six core departments. Each department is led by a Director or Manager, who reports to the relevant executive.

1.3.1 Engineering & Grid Operations

The Engineering & Grid Operations department at GreenGrid Energy is responsible for designing, maintaining, and optimizing the physical power distribution network. This includes real-time monitoring of energy flow, grid stability, and operational efficiency. The department plays a critical role in integrating renewable energy sources into the smart grid infrastructure while ensuring compliance with regulatory standards.

Core Responsibilities

The department's key responsibilities include:

- **Grid Infrastructure Management:** Overseeing the deployment, maintenance, and upgrades of smart grid components, including substations, transmission lines, and Distributed Energy Resources (DER).
- **SCADA System Operations:** Ensuring continuous monitoring and control of grid assets using SCADA systems to maintain grid stability and prevent outages.
- **Grid Security and Reliability:** Implementing resilience measures to protect against cybersecurity threats, natural disasters, and system failures.
- **OT Security:** Managing the convergence of IT and OT environments by deploying security controls for grid-connected devices and industrial control systems.
- **Incident Response and Disaster Recovery:** Developing contingency plans to mitigate risks associated with grid failures, cyberattacks, and supply chain disruptions.
- **Integration of Renewable Energy:** Managing the technical challenges of incorporating solar, wind, and other renewable energy sources into the smart grid.

Infrastructure and Technology Stack

The Engineering & Grid Operations department relies on the following core technologies:

- **SCADA Systems:** Used for real-time monitoring and control of critical grid components.

- **IoT Sensors and Smart Meters:** Providing detailed performance data from field assets to optimize energy distribution.
- **Edge Computing:** Enabling localized data processing for low-latency decision-making.
- **Hybrid Cloud Platforms (AWS/Azure):** Supporting predictive analytics, system automation, and secure data storage.
- **Firewall and Intrusion Detection System (IDS)/IPS! (IPS!) Solutions:** Ensuring network security through robust threat detection mechanisms.
- **OT/IT Network Segmentation:** Implementing strict security controls to prevent unauthorized access between corporate IT and operational networks.

Departmental Management Structure

The Engineering & Grid Operations department is led by an **Engineering & Grid Operations Manager**, who reports directly to the COO. The internal structure is organized as follows:

- **Engineering & Grid Operations Manager:** Provides strategic oversight, ensures grid stability, and aligns department objectives with company goals.
- **Grid Infrastructure Lead:** Oversees grid modernization projects, substation maintenance, and infrastructure expansion efforts.
- **SCADA and Control Systems Specialist:** Manages SCADA operations, ensuring continuous monitoring, control, and security of grid systems.
- **OT Security Engineer:** Focuses on securing grid-connected assets and mitigating cyber threats targeting operational technology.
- **Renewable Energy Integration Specialist:** Ensures seamless incorporation of renewable energy sources, optimizing grid balancing and energy distribution.
- **Field Operations Supervisor:** Coordinates on-site maintenance teams, ensuring safety compliance and operational efficiency in power distribution.

1.3.2 Research & Development Department

Focused on innovation and next-generation solutions, the RD department is dedicated to advancing smart grid technology, predictive analytics, and renewable energy systems through proprietary innovations. It ensures secure environments for technology development and rigorously safeguards intellectual property against cybersecurity threats.

Organizational Structure

To address the responsibilities of the RD department, its management includes:

- **Director of RD:** Reports directly the developments to the Chief Technology Officer (CTO) and ensures that all research initiatives align with the overall strategic objectives.

- **Algorithm Development Specialists:** Design, develop, and optimize algorithms for smart grid optimization, predictive analytics, and renewable energy management.
- **Cybersecurity and Intellectual Property Management Specialists:** Safeguard proprietary research outputs, perform security assessments, and ensure proper protection of intellectual property.
- **Prototype Testing Specialists:** Conduct rigorous testing of prototypes in controlled environments to validate functionality, performance, and compliance with security standards.

Besides the organizational structure presented, there is a strong cross-department collaboration with Engineering & Grid Operations department, to facilitate the transition of validated technologies from the development stage to practical, operational environments.

1.3.3 Customer Services & Billing

All client-facing activities—such as account management, billing, and technical support—fall under this department’s purview, serving both residential and enterprise customers. Protecting personal and financial data is paramount, requiring rigorous compliance with data privacy regulations and prompt issue resolution to maintain customer satisfaction.

1.3.4 Supply Chain Management Department

The Supply Chain Management department at GreenGrid Energy plays a crucial role in supporting the company’s operational efficiency and strategic goals. Its primary responsibilities include procuring, assessing, and managing the acquisition of hardware, software, and external services necessary for the company’s operations. Given the company’s strong emphasis on cybersecurity and compliance, this department ensures that all acquired resources and services adhere to rigorous security standards and regulatory requirements.

To address the complexity of procurement and vendor management activities effectively, the Supply Chain Management department is organized with clearly defined roles under the supervision of a Supply Chain Manager, who directly reports to the COO. The internal structure of this department is as follows:

- **Supply Chain Manager:** Responsible for strategic oversight, departmental leadership, and alignment of procurement processes with organizational objectives. Coordinates overall procurement strategies and supervises team performance.
- **Hardware Procurement Specialist:** Oversees the procurement, logistics, inventory management, and verification of all physical hardware components, such as smart-grid devices, sensors, and power management equipment. Ensures hardware security integrity and vendor reliability.
- **Software Procurement Specialist:** Manages the procurement of software assets, licenses, analytics tools, and cybersecurity solutions. Collaborates closely with the CIO and CTO to confirm software solutions align with technology strategies and cybersecurity guidelines.

- **Service Procurement Specialist:** Focuses on acquiring external services critical to operations, such as consulting engagements, technical training programs, support contracts, and maintenance services. Responsible for monitoring the quality and compliance of service providers.
- **Vendor Relationship Specialist:** Dedicated to managing strategic vendor relationships across hardware, software, and services. Conducts vendor risk assessments, security audits, and compliance verifications to mitigate supply chain-related risks.

This structure ensures clear accountability, specialization of roles, and scalability to meet future operational demands. It also aligns closely with GreenGrid Energy's cybersecurity framework by ensuring thorough vetting and continuous monitoring of all vendors and acquired resources.

The organizational hierarchy within the Supply Chain Management department is depicted below:

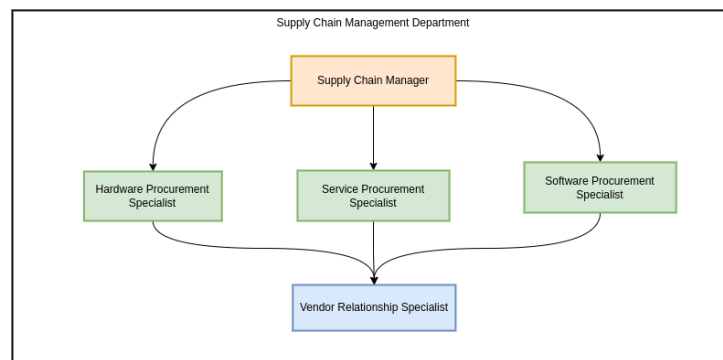


Figure 1.2: Organizational chart of Supply Chain Management Department

Through this structured organization, the Supply Chain Management department ensures efficient operations, robust security controls, and strategic alignment with GreenGrid Energy's business objectives.

1.3.5 HR

HR oversees recruitment, training, performance evaluation, and overall employee welfare. As part of the company's broader security posture, HR also manages background checks, role-based access control, and ongoing security awareness initiatives to ensure that all staff understand and adhere to established security protocols.

1.3.6 Legal & Administration

This department ensures that GreenGrid Energy remains compliant with evolving industry regulations and standards. Core tasks include contract drafting and review, regulatory monitoring, and oversight of administrative budgeting. By maintaining legal and procedural integrity, the Legal & Administration team supports the organization's ability to operate smoothly and avoid compliance risks.

1.4 Infrastructure and Security Context

1.4.1 Core Technologies and Systems

GreenGrid Energy's infrastructure comprises several critical technologies supporting operational excellence, security, and departmental integration.

SCADA Systems These systems allow real-time control and monitoring of grid equipment, essential for the reliability and stability of energy distribution operations.

Hybrid Cloud Platforms (AWS/Azure) Offer scalable computing, secure data storage, advanced analytics, and support for IoT device management, facilitating innovation and departmental collaboration.

Edge Computing Provides local data processing capabilities near physical assets, ensuring low latency and rapid response for critical grid management tasks.

Microsoft 365 The primary platform for internal communication, collaboration, and productivity across all company departments.

Systems Applications and Products (SAP) Enterprise Resource Planning (ERP) Integrates business-critical functions such as procurement, inventory management, customer services, financial oversight, and regulatory compliance.

1.4.2 Network Topology

GreenGrid Energy maintains two distinct networks to segregate operational and corporate functions securely:

- **OT Network:** Hosts grid-specific operations, including SCADA systems and field-deployed IoT devices.
- **IT Network:** Manages corporate services such as ERP systems, collaboration tools, and HR applications.

Secure segmentation between the OT and IT networks is essential to safeguard critical infrastructure operations.

1.4.3 Threat Landscape

The primary cybersecurity threats facing GreenGrid Energy include:

- **Nation-State Actors:** Target critical infrastructure for strategic objectives and disruption.
- **Advanced Persistent Threats (APTs):** Sophisticated attackers leveraging vulnerabilities in IoT and grid-related technologies.
- **Supply Chain Risks:** Compromise of hardware or software components through third-party suppliers.

1.4.4 Technology and Department Association

The following table associates each core technology with its primary departmental users, highlighting responsibility and ensuring clear governance:

Table 1.1: Core Technologies and Associated Departments

Technology/System	Primary Department(s)
SCADA Systems	Engineering & Grid Operations
Hybrid Cloud Platforms (AWS/Azure)	IT, RD
Edge Computing	Engineering & Grid Operations, RD
Microsoft 365	All Departments
SAP ERP	Supply Chain, Customer Services, Legal & Administration, HR
OT Network	Engineering & Grid Operations
IT Network	IT, Legal & Administration, HR

This clear and organized mapping ensures effective oversight, accountability, and management of cybersecurity risks across the company's operational infrastructure.

Chapter 2

ISMS Scope

Aligned with ISO/IEC 27001 Clause 4.3 guidelines,⁴ this chapter details GreenGrid Energy’s *ISMS* scope by identifying the key stakeholders, describing shared IT infrastructure, highlighting core business processes, and specifying the boundaries within which the ISMS will operate.

2.1 Organizational Stakeholders

GreenGrid Energy’s stakeholders, as defined by ISO/IEC 27001, include both internal and external entities that can influence—or be influenced by—the organization’s security practices.⁶ Table 2.1 summarizes the principal stakeholder groups and their roles in relation to the ISMS.

Table 2.1: Stakeholders and ISMS Interaction

Stakeholder Group	Interaction with the ISMS
Executive Management and Board	Provide strategic oversight, allocate resources, approve ISMS scope, and review security performance.
IT Department	Implement and maintain technical security controls; daily management of the ISMS infrastructure.
Department Heads and Employees	Comply with ISMS policies, handle information securely, report incidents, and participate in risk assessments.
Customers and Clients	Expect protection of data confidentiality, integrity, and availability as part of service agreements.
Suppliers and Third-Party Providers	Comply with contractual security requirements to ensure the security of GreenGrid data processed externally.
Regulators and Authorities	Expect adherence to industry regulations and may audit ISMS practices and compliance.
Certifying Bodies/Auditors	Evaluate and validate compliance with ISO/IEC 27001 through periodic certification audits.

2.2 Shared IT Infrastructure and Systems

GreenGrid Energy employs a centrally managed IT infrastructure used across multiple departments. Key elements of this shared environment include:

- **Network Infrastructure:** Company-wide network including Local Area Network (LAN), secure Wi-Fi, and Virtual Private Network (VPN) for remote employees.
- **Server and Cloud Systems:** Hosting internal applications, databases, and departmental services.
- **Enterprise Applications:** Microsoft 365, SAP ERP, and Customer Relationship Management (CRM) software supporting business operations and collaboration.
- **User Devices:** Managed desktop computers, laptops, and mobile devices.
- **Data Storage and Backup Systems:** Centralized data repositories and backup solutions.
- **Communication and Collaboration Tools:** Email systems, instant messaging platforms, video conferencing, and intranet portals.

Each department relies on these resources for day-to-day operations. Chapter 3 will focus on specific requirements, objectives, and policies around these systems, while this chapter captures their basic description for scope purposes.

2.3 Business Processes, Data, and Security Risks by Department

2.3.1 Engineering & Operations

The Engineering & Operations Department serves as the backbone of GreenGrid Energy's infrastructure, ensuring the seamless integration and reliable performance of smart-grid technologies and renewable energy systems. This department is responsible for designing, deploying, and maintaining critical operational assets, balancing efficiency, scalability, and cybersecurity. The ISMS scope encompasses key operational processes, addressing risks associated with grid stability, system automation, and industrial control systems while aligning with the organization's broader security objectives.

Grid Infrastructure Management:

- **Activities:** Overseeing deployment, maintenance, and modernization of grid components.
- **Data Processed:** Grid topology data, maintenance logs, infrastructure monitoring reports.
- **Cybersecurity Risks:** Unauthorized system modifications, physical and cyber tampering, outdated firmware vulnerabilities.
- **Technologies:** SCADA systems, asset management platforms, industrial-grade firewalls.

SCADA System Operations:

- **Activities:** Monitoring and controlling grid assets for stability and reliability.
- **Data Processed:** Real-time grid performance data, event logs, control commands.
- **Cybersecurity Risks:** Remote access exploitation, SCADA malware, data interception.
- **Technologies:** Secure remote access solutions, IDS, encrypted communication channels.

Incident Response and Disaster Recovery:

- **Activities:** Developing and executing contingency plans for cyber and operational incidents.
- **Data Processed:** Incident reports, forensic data, response logs.
- **Cybersecurity Risks:** Prolonged downtime, inadequate threat response, lack of forensic integrity.
- **Technologies:** Automated threat detection, backup and recovery solutions, Security Information and Event Management (SIEM) platforms.

Renewable Energy Integration:

- **Activities:** Managing the integration of solar, wind, and other renewable energy sources.
- **Data Processed:** Renewable generation data, demand-response metrics, battery storage status.
- **Cybersecurity Risks:** Grid imbalances, data manipulation, unauthorized control access.
- **Technologies:** Smart inverters, edge computing for energy optimization, blockchain for energy transactions.

2.3.2 Research & Development (R&D)

The RD Department plays a strategic role at GreenGrid Energy, providing innovative solutions essential for enhancing smart-grid operations and renewable energy technologies. The ISMS scope outlines the department's core processes, explicitly highlighting the data handled, relevant cybersecurity risks, and utilized technologies, aligning with the ISMS objectives.

Proprietary Research and Innovation Process

This process involves identifying, researching, and evaluating emerging technologies and concepts that can potentially enhance grid efficiency and reliability.

Activities:

- Market and technology research

- Feasibility analysis and experimentation
- Preliminary risk assessment of potential innovations

Data Processed:

- Market intelligence data
- Experimental research results

Cybersecurity Risks:

- Data leakage of research findings
- Unauthorized access to research environments

Technologies:

- Cloud platforms
- Research databases and analytics tools

Algorithm and Software Development

This process is dedicated to the systematic creation and validation of predictive analytics algorithms and software for operational use in grid optimization and energy distribution forecasting.

Activities:

- Specification of requirements
- Software coding and iterative development cycles
- Simulation-based testing and validation
- Continuous security assessments during development

Data Handled:

- Proprietary algorithmic code
- Simulated and historical grid data

Security Risks:

- Intellectual property theft
- Vulnerabilities in software code

Technologies:

- Advanced simulation tools
- Code repositories and CI/CD pipelines

Prototype Development and Testing

Prototypes of innovative solutions are built and securely tested to verify their effectiveness, reliability, and resilience to cyber threats.

Activities:

- Development of technology prototypes
- Secure environment configuration for testing
- Conducting controlled cybersecurity assessments
- Documentation and analysis of testing outcomes

Data Handled:

- Prototype technical specifications
- Test results and security assessments

Security Risks:

- Leakage of sensitive design specifications
- Unauthorized access during testing phases

Technologies Used:

- Testing and simulation environments
- Computing infrastructures

Intellectual Property Protection

Ensuring strong protection of intellectual property is essential for maintaining the competitive edge and minimizing risks of industrial espionage and data breaches.

Activities:

- Documentation and protection of R&D outputs
- Management of patent filing processes
- Regular security audits for IP management

Data Handled:

- Intellectual property records and documentation
- Sensitive research outcomes

Security Risks:

- Industrial espionage attempts
- Intellectual property data breaches

Technologies Used:

- Secure data storage solutions
- Encryption and secure communication tools

Technology Integration and Collaboration

This process focuses on transitioning validated technologies from the R&D department into operational use, working closely with Engineering & Grid Operations.

Activities:

- Collaborative planning and joint validation sessions
- Cross-departmental training and knowledge transfer
- Monitoring and support during initial deployment phases

Data Handled:

- Integration plans and documentation
- Performance and reliability data from integration tests

Security Risks:

- Integration-related vulnerabilities
- Compromise during the operational handover process

Technologies Used:

- Collaboration platforms (Microsoft 365, Jira)
- Secure configuration management systems

2.3.3 Customer Services

Key Processes and Data: Client contracts, billing data, CRM, customer Personally Identifiable Information (PII)

Security Risks: Privacy breaches, financial fraud, unauthorized data disclosure

2.3.4 Finance

Key Processes and Data: Financial management (budgeting, transactions, payroll, ERP financial module)

Security Risks: Financial fraud, phishing attacks, unauthorized access, data tampering

2.3.5 Supply Chain Management

Procurement and Sourcing

Oversees the end-to-end procurement lifecycle for hardware, software, and services by:

- Drafting Requests for Proposals (RFPs) or Requests for Quotes (RFQs).
- Conducting vendor evaluations and security due diligence.
- Negotiating contracts and maintaining supplier agreements.

Associated data supporting this process:

- Vendor profiles and security certifications.
- Product specifications (e.g., smart grid components, software licenses).
- Pricing details, purchase orders, and invoices.

Vendor Relationship Management

Manages ongoing relationships with approved suppliers to ensure adherence to GreenGrid Energy's security and performance standards by:

- Monitoring Service-Level Agreement (SLA) requirements.
- Tracking vendor performance and compliance metrics.
- Conducting periodic vendor risk assessments, especially for critical components.

Relevant data for this process:

- Contract terms and SLA metrics.
- Vendor incident reports or audit findings.
- Communication records (emails, project updates, meeting minutes).

Inventory & Logistics Coordination

Coordinates warehousing, transportation logistics, and inventory control once goods or services are procured by:

- Tracking shipment and delivery status of hardware components.
- Verifying integrity and authenticity of infrastructure parts.
- Overseeing storage, handling, and distribution to operational sites.

Data types maintained in this process:

- Shipping documentation (e.g., bills of lading, customs paperwork).
- Inventory levels and restocking details.
- Asset tracking logs (equipment serial numbers, batch numbers).

Compliance and Risk Management

Ensures that supplier relationships and procurement activities meet security policies and relevant regulations by:

- Reviewing supplier security audits and certifications.
- Ensuring compliance with data protection and trade regulations.
- Coordinating corrective actions for supplier or logistics risks.

Data associated with this process:

- Audit reports, compliance checklists, and regulatory filings.
- Documentation of risk treatment actions (vendor replacements, contract updates).
- Internal approval records and compliance sign-offs.

Contract and SLA Oversight

Manages contractual obligations from initial sign-off to renewal or termination by:

- Monitoring contract milestones (renewal dates, penalty clauses).
- Ensuring suppliers meet service quality and security requirements.
- Handling contract amendments for security or operational changes.

Key data involved:

- Master Service Agreements (MSAs), Statements Of Work (SOWs).
- Change requests and contract amendment records.
- Legal correspondence regarding contract disputes or terminations.

2.3.6 Human Resources

Key Processes and Data: Employee management (personal records, payroll data, performance data)

Security Risks: Unauthorized disclosure, insider threats, privacy breaches

2.3.7 IT Department

Key Processes and Data: Infrastructure management (network devices, servers, endpoint devices, IAM systems, incident response data)

Security Risks: System compromise, configuration errors, misuse of admin privileges

2.3.8 Sales and Marketing

Key Processes and Data: Customer relationship management (CRM), market data, public-facing web resources

Security Risks: Unauthorized access, reputation damage, phishing/malware attacks

2.4 ISMS Boundaries and Exclusions

The ISMS boundaries include:

- Internal IT and OT networks, including SCADA and enterprise systems used by the Supply Chain Management, Customer Services & Billing, and Research & Development departments.
- Data processing within cloud environments generated or consumed by Supply Chain Management, Customer Services & Billing, and Research & Development.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Explicit exclusions from the ISMS scope include:

- Third-party systems fully managed externally, where GreenGrid has no direct control.
- Personal employee devices not centrally managed by the organization.
- Physical security at externally managed premises (e.g., leased data centers).
- Separate subsidiaries or partner organizations outside direct oversight.

These exclusions are justified by the lack of direct administrative oversight or practical manageability; any associated risks are mitigated through contractual obligations and vendor assessments.¹

Chapter 3

Information Security Policy and Objectives

This chapter addresses the next phase of establishing GreenGrid Energy's ISMS by incorporating stakeholder requirements, business goals, security objectives, leadership commitment, and overall compliance needs.

3.1 Stakeholder Requirements and Business Goals

As established in Chapter 2, GreenGrid Energy's stakeholders include Executive Management, the IT Department, Department Heads & Employees, Suppliers, Clients, Regulators, and Certifying Bodies. Because the ISMS scope specifically includes:

- Internal IT and OT networks, including SCADA and enterprise systems used by **Supply Chain Management, Customer Services & Billing**, and **RD** departments.
- Data processing within cloud environments generated or consumed by **Supply Chain Management, Customer Services & Billing**, and **RD**.
- Procurement processes and vendor management.
- Employee data, access management, and training processes.

Most stakeholder requirements focus on ensuring robust controls to protect:

- Critical infrastructure.
- Sensitive customer and financial data.
- Intellectual property from RD activities.
- Secure procurement of hardware/software through the Supply Chain Management department.
- Proper handling of employee data and permissions.

In contrast, stakeholders agree that **third-party systems fully managed externally**, **personal employee devices**, **physical security at externally managed premises**, and **separate subsidiaries or partner organizations outside direct oversight** are explicitly out of scope, thus reducing direct stakeholder interest in those areas.

3.2 Leadership Commitment

GreenGrid Energy's board of directors reinforce the ISMS by:

- **Allocating Sufficient Budgets:** Funding security tools and training for departments within the ISMS boundaries.
- **Championing Policy Adoption:** Ensuring all employees and department heads integrate the new Information Security Policy into their daily operations.
- **Encouraging a Security Culture:** Mandating ongoing training on secure processes, especially for staff involved in vendor management and grid operations.
- **Reviewing ISMS Performance:** Conducting periodic management reviews to track key risk metrics, incident reports, and audit findings.

3.3 Monitoring and Review of ISMS Performance

To ensure continuous improvement, GreenGrid Energy will measure and review ISMS effectiveness through:

- **Annual ISMS Audit:** Conduct full audits and ensure corrective actions for non-conformities.
- **Key Risk Indicators (KRIs):** Monitor unauthorized access attempts, security incidents, and policy violations.
- **Management Review Meetings:** Perform biannual ISMS performance reviews with Executive Management.

3.4 Risk Management Goals and Compliance Requirements

Given the potential threats to the included systems and data, the organization sets forth the following overarching risk management goals:

- **Protect OT and IT Convergence:** Keep SCADA, IoT, and enterprise networks resilient against cyber threats.
- **Safeguard Data Privacy and Integrity:** Ensure confidentiality of customer billing data, vendor records, and intellectual property from RD.
- **Maintain Regulatory Compliance:** Satisfy relevant European Union (EU) directives such as NIS 2, and meet ISO/IEC 27001 standards to secure continuous certification and avoid penalties.
- **Mitigate Vendor and Procurement Risks:** Enforce security checks during procurement of critical hardware/software, and conduct regular vendor risk assessments.
- **Enhance Incident Response Preparedness:** Develop rapid containment strategies for security breaches or supply chain disruptions, minimizing downtime of grid operations.

3.5 Information Security Policy (Clause 4.2)

Policy Statement

GreenGrid Energy is committed to safeguarding the confidentiality, integrity, and availability of information assets within the boundaries of its ISMS, specifically covering:

- Internal IT and OT networks that power core operations.
- Data processed through corporate cloud environments.
- Procurement and vendor relationships supporting operational continuity.
- Employee access management, training, and HR-related records.

Key Principles

- **Risk-Based Controls:** Security measures must be tailored to identified threats, focusing on high-risk areas such as SCADA, third-party supplier links, and RD data.
- **Legal and Regulatory Compliance:** Adhere to ISO/IEC 27001, Network and Information Systems Directive II (NIS2), and national data protection laws relevant to energy operations.
- **Continuous Improvement:** Policies, controls, and training programs will be reviewed at least annually or following major incidents.

Responsibilities

- **CISO:** Oversees policy implementation and audits across IT, OT, and supply chain operations.
- **Department Directors:** Ensure departmental processes adhere to this policy; sponsor secure practices among staff.
- **All Employees:** Follow approved procedures, maintain vigilance for potential threats, and report incidents promptly.

3.6 Department-Specific Security Objectives (Clause 6.2)

Below are the measurable information security objectives for each major department within the ISMS scope. Each subsection also highlights the primary stakeholders driving or benefiting from these goals.

3.6.1 Engineering & Operations

Stakeholders:

- **Grid Operations Teams:** Manage real-time grid stability and control systems.

- **SCADA and Industrial Control Engineers:** Maintain secure and reliable SCADA environments.
- **Regulatory Authorities:** Oversee compliance with national and EU grid security regulations.
- **IT Security and Network Teams:** Secure OT/IT convergence to protect grid operations.

Objectives:

- **Objective EO-1: Strengthen SCADA System Security**
 - **Target:** Ensure 100% of SCADA systems have up-to-date security patches and network segmentation controls.
 - **Measure:** Compliance rate of SCADA system updates and segmentation audits.
 - **Owner:** SCADA Security Team, CISO.
- **Objective EO-2: Improve OT Network Visibility and Anomaly Detection**
 - **Target:** Deploy real-time monitoring tools to achieve a 90% anomaly detection rate in OT networks.
 - **Measure:** Number of security alerts detected vs. actual threats mitigated.
 - **Owner:** Engineering Security Lead, IT Security Team.
- **Objective EO-3: Enhance Physical and Cyber Resilience of Grid Infrastructure**
 - **Target:** Perform biannual security assessments for grid substations and power distribution control centers.
 - **Measure:** Number of identified vulnerabilities mitigated before next assessment cycle.
 - **Owner:** Grid Operations Manager, CISO.

3.6.2 Supply Chain Management

Stakeholders:

- **Supply Chain Staff:** Procurement Specialists and Vendor Relationship Managers who oversee supplier performance and risk.
- **Vendors and Third Parties:** Partners required to comply with our stringent security checks, audits, and contractual requirements.
- **Executive Management:** Needs assurance of an uninterrupted, secure supply of components to support operational continuity and protect the company's reputation.

Objectives:

- **Objective SC-1: Reduce High-Risk Vendor Gaps**

To lower the risk of compromised components or software infiltrating GreenGrid Energy's infrastructure, it is essential that our critical suppliers adhere to rigorous security standards. This proactive auditing approach helps prevent operational disruptions, regulatory non-compliance, and reputational damage.

- **Target:** Audit at least 100% of all critical hardware/software suppliers annually.
- **Measurement:** Track the percentage of audited suppliers, monitor the number and closure time of security findings, and evaluate any security incidents attributable to supplier issues.
- **Owner:** Supply Chain Manager and CISO.

- **Objective SC-2: Maintain Rapid Supplier Incident Response**

Minimizing supply chain downtime is vital to avoiding customer dissatisfaction and churn. Quick resolution of disruptions ensures that delays do not negatively impact our operations or customer trust.

- **Target:** Ensure that supply chain incidents are resolved within a maximum of 45 minutes, except in cases of natural disasters or other uncontrollable events.
- **Measurement:** Monitor the average resolution time, count incidents exceeding the 45-minute threshold, and track customer feedback or churn linked to supply chain delays.
- **Owner:** Supply Chain Manager and CISO.

3.6.3 Research & Development (RD)

Stakeholders:

- **RD Teams:** Create proprietary analytics algorithms and software for grid optimization.
- **Executive Management:** Relies on RD innovation for market competitiveness.
- **Intellectual Property Owners:** Concerned about protecting patents, code repositories, trade secrets.

Objectives:

- **Objective RD-1: Prevent Unauthorized Access to RD Data** It is vital that the innovation data on GreenGrid Energy's Infrastructure remains unaccessed in a non authorized way, as such data includes confidential information that could cause reputational damage and eventual software damage on the infrastructure.

- **Target:** Achieve a 50% reduction in unauthorized access attempts and security alerts within the RD environment.
- **Measure:** Number of RD-specific security alerts against the prior reporting period.
- **Owner:** RD Manager, IT Department.

- **Objective RD-2: Strengthen Security of Environments** Since the environments on the RD Department are critical, attacks on its infrastructure are to be avoided. Strengthening security on the environments ensures the attacks and vulnerabilities don't affect the service provided.
 - **Target:** Perform quarterly audits of RD environments to identify and mitigate vulnerabilities.
 - **Measure:** Audit completion rate.
 - **Owner:** Director of RD IT Security Team.

Chapter 4

Other Security Policies and Procedures

In addition to our main Information Security Policy, GreenGrid Energy implements several additional organization-wide security policies and corresponding procedures. These measures support our compliance with ISO/IEC 27001 Annex A and ensure that all aspects of our security posture are addressed consistently across the organization.

4.1 Other Security Policies

4.1.1 Access Control Policy

Purpose: To ensure that access to information assets is granted only to authorized individuals in accordance with the principle of least privilege.

Scope: Applies to all employees, contractors, and third parties who access GreenGrid Energy's information systems.

Policy:

- Access rights are assigned based on roles and responsibilities.
- All access requests must be formally documented, approved, and periodically reviewed.
- Multi-factor Authentication (MFA) is required for accessing sensitive systems.

Enforcement: Failure to comply with access control procedures may result in restricted access, mandatory retraining, or disciplinary action, including termination if misuse is severe.

Responsibilities: The IT Department, in collaboration with HR and departmental managers, is responsible for the implementation and monitoring of access controls.

4.1.2 Data Classification Policy

Purpose: To classify information according to its sensitivity and ensure that it is handled appropriately to prevent unauthorized disclosure, modification, or destruction.

Scope: Applies to all data owned or processed by GreenGrid Energy.

Policy:

- Information shall be classified as Public, Internal, Confidential, or Restricted.

- Handling, storage, and transmission procedures will be defined based on the data classification.
- Regular reviews will ensure that classification levels remain accurate and effective.

Enforcement: Any violation of the data classification guidelines may lead to corrective measures such as access restrictions, formal warnings, and potential legal action in case of data breaches.

Responsibilities: Department heads are responsible for classifying information within their areas, while the IT Department ensures secure storage and transmission.

4.1.3 Incident Response Policy

Purpose: To establish a clear process for reporting, managing, and resolving security incidents efficiently.

Scope: All employees and third-party providers who use or manage GreenGrid Energy's information systems.

Policy:

- All security incidents must be reported immediately to the IT Security Team.
- An IRP is in place to contain, eradicate, and recover from incidents.
- A post-incident review is conducted to capture lessons learned and implement corrective measures.

Enforcement: Non-compliance with incident reporting procedures or failure to follow the response plan may result in disciplinary action, including termination, and can lead to further legal consequences if negligence results in significant harm.

Responsibilities: The IT Security Team, led by the CISO, is responsible for managing incident response and ensuring that all incidents are documented and reviewed.

4.1.4 Responsible IT Resource Usage Policy

Purpose: To promote the secure and efficient use of GreenGrid Energy's IT resources in support of business operations while maintaining data integrity.

Scope: This policy applies to all employees, contractors, and temporary staff who access or use GreenGrid Energy's IT systems and devices.

Policy:

- IT resources should primarily support work-related activities and organizational goals.
- Users must protect their access credentials and handle sensitive information responsibly.
- Personal use of IT resources is allowed only if it does not interfere with work duties or compromise system security.
- All IT resource usage must comply with applicable laws, regulations, and company policies.

Enforcement: Violations of this policy may lead to corrective measures such as access suspension, formal warnings, mandatory retraining, or disciplinary actions up to and including termination.

Responsibilities: Department Heads are responsible for ensuring that their teams understand and adhere to this policy, while the IT Department monitors usage and implements necessary safeguards.

4.2 Other Security Procedures

For each of the above policies, the following procedures provide detailed, step-by-step instructions for implementation and operational management. Beyond simply stating how tasks are carried out, these procedures also outline how data produced by or for the ISMS—such as audit logs, classification labels, or incident records—are securely stored, accessed, and disposed of.

4.2.1 Access Control Procedure

- **Document and Approve Access Requests:** All new access requests must be submitted via the official request form and approved by the department manager and IT Security.
- **Periodic Access Reviews:** Perform quarterly audits to ensure that user privileges align with current roles and responsibilities; remove or adjust access as needed.
- **MFA:** Enable and maintain MFA for sensitive systems, ensuring credentials are stored securely and never shared.
- **Protecting ISMS Data:** Access logs, approval workflows, and any reports on privileges are labeled *Restricted*, stored in an encrypted repository, and shared only with authorized personnel.

4.2.2 Data Classification Procedure

- **Identify and Label Assets:** Classify data as Public, Internal, Confidential, or Restricted according to the Data Classification Policy.
- **Storage and Handling Guidelines:** For each classification level, follow approved controls (e.g., encryption for Restricted data, restricted folder permissions for Confidential).
- **Periodic Review and Update:** Conduct semiannual checks to validate that classification labels remain accurate as business processes evolve.
- **Protecting ISMS Data:** All classification records and any logs describing data reclassification are stored on a secure server with role-based access. Any reclassification decisions are documented and version-controlled.

4.2.3 Incident Response Procedure

- **Immediate Reporting:** All security incidents must be reported to the IT Security Team or the Incident Response Coordinator within 15 minutes of discovery.
- **Containment, Eradication, and Recovery:** Follow the IRP to isolate affected systems, remove malicious artifacts, and restore operations with minimal downtime.
- **Post-Incident Review:** Conduct a root cause analysis to identify vulnerabilities or process gaps and document lessons learned for continuous improvement.
- **Protecting ISMS Data:** All incident reports, investigation notes, and evidence are tagged *Confidential*, stored in a secure incident database accessible only to the Incident Response Team, and retained for the legally required duration.

4.2.4 Responsible IT Resource Usage Procedure

- **Policy Distribution and Acknowledgment:** The Responsible IT Resource Usage Policy is circulated to all new hires and existing employees; each individual must acknowledge it in writing or via an online form.
- **Usage Monitoring:** The IT Department periodically reviews network and system logs for suspicious or excessive personal use. Violations are escalated as per HR guidelines.
- **Incident Handling:** If a misuse incident is detected, a formal investigation is initiated, and appropriate disciplinary measures (including revoking certain privileges) may be applied.
- **Protecting ISMS Data:** All logs and records regarding user behavior are labeled at least *Internal* and stored on secure servers. Only HR, the IT Security Team, and relevant department managers have access for investigative purposes.

Chapter 5

Risk Management Framework

This chapter presents the basic components of GreenGrid Energy's information security risk management programme. It outlines the Risk Assessment Policy, the Risk Assessment and Treatment Processes, and includes an Asset Inventory developed in accordance with ISO/IEC 27001 Clause 6.1.2 and Annex A 5.9.

5.1 Risk Assessment Policy

Purpose and Scope

This policy defines GreenGrid Energy's approach to identifying, assessing and managing information security risks. It applies to all information systems, assets, business processes and personnel within the scope of the ISMS.

Objectives

- Establish a structured and repeatable approach to risk identification and analysis.
- Support informed decision making regarding the implementation of security controls.
- Ensure compliance with applicable legal, regulatory and contractual requirements.

Governance and Risk Appetite

GreenGrid Energy maintains a conservative risk appetite, particularly for critical infrastructure such as SCADA systems and sensitive customer information. Risks rated *High* or *Medium-High* require mandatory treatment and cannot be accepted without mitigation.

5.2 Risk Assessment Process

Overview

The risk assessment process consists of three main stages:

1. **Risk Identification:** Mapping assets, associated threats, vulnerabilities and their potential impact.

2. **Risk Analysis:** Assessing the likelihood and impact of threat scenarios.
3. **Risk Assessment:** Comparing the analysed risk levels with predefined risk acceptance criteria.

Methodology

Risks are analysed using a **Risk Level Matrix**, which combines the likelihood of an incident occurring with the severity of its impact. The matrix follows a 5x5 scale with risk levels classified as low, medium, high or critical. This structured approach enables a consistent and visual prioritisation of risks.

		Impact →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Figure 5.1: Risk level matrix used by GreenGrid Energy²

The matrix serves as a decision-making tool to identify which risks require immediate treatment and which can be accepted under defined conditions.

5.2.1 Risk Identification

Asset Inventory

As part of the risk identification process required by ISO/IEC 27001, a complete asset inventory was developed and classified according to security relevance and operational context. This inventory includes both IT and OT assets and was used as a reference to assess risk levels based on the Confidentiality, Integrity, and Availability (CIA) triad.

The full inventory is presented in Appendix A, where assets are organised by department and include detailed technical and risk-related attributes.

5.2.2 Risk Analysis

Following the identification of relevant assets and their classification according to Confidentiality, Integrity, and Availability (CIA), a structured risk analysis was performed. This process involved evaluating the likelihood and potential impact of various threat scenarios targeting the organisation's information assets.

The methodology applied is based on a qualitative risk matrix approach, combining the likelihood of occurrence with the impact level to determine the severity of each risk. Likelihood levels were derived from historical incident trends, industry threat intelligence, and system exposure (e.g., public-facing interfaces or outdated software). Impact levels were assessed considering the potential consequences on operations, legal compliance, financial stability, and reputation.

The risk matrix used by GreenGrid Energy, shown in Figure 5.1, categorises risks into four levels: Low, Medium, High, and Critical. These categories support the prioritisation of treatment measures in the subsequent phase.

5.2.3 Risk Assessment

The risk assessment stage consists of comparing the analysed risk levels with GreenGrid Energy's defined risk acceptance criteria. Risks classified as High or Critical are considered unacceptable and require mandatory treatment through mitigation, transference, or avoidance. Medium-level risks may be tolerated if justified and documented with compensatory controls or a monitoring strategy. Low-level risks are generally accepted, but still logged for periodic review.

Each identified risk was documented with:

- Affected asset and department;
- Identified threat or vulnerability;
- Likelihood and impact rating;
- Calculated risk level (from the matrix);
- Proposed treatment or justification for acceptance.

The outcome of the risk assessment provides the foundation for the selection and implementation of appropriate security controls, ensuring alignment with both ISO/IEC 27001 and GreenGrid Energy's operational needs and risk appetite.

5.3 Risk Treatment Process

Treatment Options

Risks that exceed acceptable thresholds shall be managed using one or more of the following strategies:

- **Mitigation:** Implementing controls to reduce the likelihood or impact of the risk.
- **Acceptance:** Accepting the risk when its impact is negligible or mitigation is not cost effective.
- **Transference:** To transfer the risk to a third party (e.g. by insurance or outsourcing).
- **Avoidance:** Elimination of the risk by cessation of the associated activity.

GreenGrid Energy follows the treatment approach outlined below:

- **High and Medium-High risks** must be mitigated. If mitigation is not possible internally, the risk will be transferred to a competent third party for resolution.
- **Medium risks** will be transferred to qualified external entities for management.
- **Low and low-medium risks** are generally accepted. However, treatment may be considered if there are no higher priority risks pending.

Implementation

A formal plan shall be developed for each risk requiring treatment, including

- The chosen management strategy.
- Designated stakeholders responsible for implementation.
- Implementation schedules and defined monitoring mechanisms.

Chapter 6

Risk Assessment Report

This chapter summarises the output of the formal risk assessment carried out for GreenGrid Energy. The process complies with ISO/IEC 27001 Clause 8.2 and uses the methodology specified in Chapter 5, applied to the critical assets listed in Appendix A. Likelihood and impact were estimated with the GreenGrid Energy risk-matrix shown in Figure 5.1; the resulting risk levels drive the Statement of Applicability (SoA) in Chapter 7.

6.1 Shared assets

Shared assets include the company-wide ERP instance, the central IT network stack, and services managed by HR and customer services. Because these systems cross functional boundaries, a successful attack could propagate quickly, increasing both the impact and cost of remediation.

Asset ID	Threat	Vulnerability	Likelihood	Impact	Risk Level
ERP-301	Data Breach	Poor access controls	Possible	Severe	Medium-High
IT-201	Phishing Attacks	Insufficient staff training	Very Likely	Significant	High
IT-202	Unauthorised Access	Firewall misconfiguration	Possible	Significant	Medium-High
CS-401	Data Leakage	Improper permission management	Possible	Significant	Medium-High
HR-501	Insider Threat	Excessive user privileges	Possible	Significant	Medium-High
HR-502	Staff Unavailability	High dependency on key staff	Possible	Significant	Med-High

The assessment highlights two systemic drivers:

- **Privilege abuse** Four of the six entries are due to weak or excessive privileges, so there is a high return on investment in strengthening **IAM!** (IAM!).

- **Human factors** The IT-201 phishing scenario scores *High* even though no technical vulnerability is exploited - demonstrating that staff security culture is as critical as tools.

Mitigation must therefore balance technical hardening with ongoing awareness training and succession planning for key roles.

6.2 RD Department

The RD Department at GreenGrid Energy is dedicated to innovation and the advancement of smart grid technologies. Given its critical role in safeguarding intellectual property and proprietary technologies, it is essential to systematically identify, assess, and mitigate risks related to cybersecurity threats, data integrity, and operational disruptions.

This risk assessment aligns with the ISO/IEC 27001 standard and forms part of the organization's ISMS.

6.2.1 Asset Inventory

Key assets within the scope of this assessment include:

- **Prototype Simulation Clusters:** Essential for testing and validating new technologies.
- **Algorithm and Software Development Platforms:** Contain proprietary algorithms and code.
- **Research Databases and Cloud Repositories:** Storage and processing of experimental data and intellectual property.

These assets have been classified based on their CIA requirements:

Asset	Confidentiality	Integrity	Availability
Prototype Simulation Clusters	High	High	Medium
Algorithms and Software Platforms	High	High	High
Research Databases and Repositories	High	High	High

6.2.2 Risk Identification

Risks specific to the RD environment were identified as follows:

- **Data Breach or Intellectual Property Theft:** Unauthorized external or internal access.
- **Cyberattacks on Testing Environments:** Potential compromise through ransomware or malware.
- **Access Control Vulnerabilities:** Inadequate management of user privileges.
- **Data Loss or Corruption:** Insufficient backup and disaster recovery procedures.

6.2.3 Risk Analysis

Using GreenGrid's Risk Level Matrix, the risks were analyzed based on their likelihood and potential impact:

Identified Risk	Likelihood	Impact	Risk Level
Unauthorized access to proprietary IP	Likely	Major	High
Ransomware targeting RD systems	Possible	Critical	High
Insider threat leading to data compromise	Possible	Major	High
Data corruption in testing environments	Unlikely	Moderate	Medium
Lack of MFA	Likely	Moderate	Medium

6.2.4 Risk Assessment and Treatment

Risks categorized as High or Medium require defined treatment strategies:

High Risks:

- **Unauthorized access to proprietary IP:** Implement strict RBAC, data encryption, and audit logging.
- **Ransomware targeting RD systems:** Enhance endpoint security, implement antivirus and antimalware solutions, and perform continuous vulnerability assessments.
- **Insider threats:** Establish comprehensive access reviews, enhanced logging, and regular employee security training.

Medium Risks:

- **Data corruption in testing environments:** Strengthen backup procedures and validate backup integrity regularly.
- **Lack of MFA:** Enforce MFA across all RD platforms to prevent unauthorized access.

6.2.5 Implementation and Monitoring

The RD department will implement the following:

- **Encryption** for sensitive data, both at rest and in transit.
- **Quarterly audits** of user access rights and system vulnerabilities.
- **IRP** tailored to the RD environment.
- **Regular employee training and awareness programs** focusing on cybersecurity best practices.

6.3 Supply-chain assets

The supply chain department relies almost entirely on the corporate ERP platform to manage purchase orders, supplier master data and inbound logistics scheduling. Although the asset is physically shared, its Supply Chain Management (SCM) data flows, integrations and uptime requirements are different from those of finance or HR.

Asset ID	Threat	Vulnerability	Likelihood	Impact	Risk Level
ERP-301	Supply Chain Compromise	Insecure third-party integrations	Possible	Severe	Medium-High
ERP-301	Data Integrity Loss	Configuration errors, incorrect updates	Possible	Significant	Medium-High
ERP-301	System Downtime	Single point of failure	Unlikely	Severe	Medium-High

The key issue here is external trust. Unverified vendor Application Programming Interface (API)s or tampered firmware could inject malicious code directly into production, bypassing perimeter defences. Similarly, a prolonged ERP outage would freeze purchase orders and delay network maintenance spares, exposing the organisation to regulatory penalties. Supplier security clauses, robust end-to-end change management and geographically redundant hosting are therefore priority controls.

Chapter 7

Statement of Application

This chapter maps each risk identified in the assessment to the relevant ISO/IEC 27001:2022 Annex A controls³ and documents whether a control is *included* or *excluded*. For clarity, the items are grouped into two categories:

- **Shared Assets** – Information-system components and services that are shared across the organisation.
- **Departmental Assets** – Assets that belong to, or are primarily managed by, a particular department.

7.1 Shared Assets

The common assets listed in this section underpin the organisation’s overall business operations - finance, people, customer engagement and core IT infrastructure. Because a single vulnerability can affect multiple functions, the controls are selected not only to mitigate the specific risk, but also to strengthen the resilience of the broader environment. The table below shows how each identified threat is addressed, together with the rationale for including or legitimately excluding each Appendix A control.

Table 7.1: Statement of application for shared assets

Asset ID	Threat	Control(s) (Annex A)	Justification for Inclusion/Exclusion
ERP-301	Data-breach (access-control failure)	A.9.1.1, A.9.4.1	Critical system; access-policy enforcement mandatory.
IT-201	Phishing / social-engineering attack	A.6.3.1, A.7.2.2	User awareness is primary defence; inclusion essential.
IT-202	Network misconfiguration	A.13.1.1, A.12.4.1	Network segmentation and logging indispensable.

Table 7.1: Statement of application for shared assets

Asset ID	Threat	Control(s) (Annex A)	Justification for Inclusion/Exclusion
CS-401	Data leakage (excessive permissions)	A.9.2.3, A.9.2.5	Periodic permission reviews prevent leakage.
HR-501	Insider threat (malicious privileged user)	A.9.2.5, A.12.4.3	Privileged-activity oversight is critical.
HR-502	Staff unavailability / single point of knowledge	A.17.1.1, A.5.30	Succession planning and redundancy required.

Taken together, the controls selected strengthen the confidentiality, integrity and availability of the organisation’s most widely used assets. *ERP-301* sits at the heart of finance, HR and supply chain workflows, so strengthening access governance via A.9 is non-negotiable - a compromised account could otherwise expose the entire corporate dataset. *IT-201* illustrates that social engineering remains a quick way to bypass technical safeguards; ongoing awareness programmes (A.6.3.1) and scheduled refresher training (A.7.2.2) directly reduce the success rate of such attacks. For *IT-202*, granular network zoning (A.13.1.1) combined with correlated event logging (A.12.4.1) enables rapid detection and isolation of any misconfigured firewall rule. The customer records server, *CS-401*, relies on strict least privilege (A.9.2.x); quarterly access reviews eliminate dormant high-privilege accounts that could leak personally identifiable information. Privileged HR roles in *HR-501* handle payroll and medical records; extensive logging of admin sessions (A.12.4.3) provides both deterrence and evidence. Finally, *HR-502* addresses business continuity: cross-training and an up-to-date succession matrix (A.17.1.1, A.5.30) safeguard critical knowledge and ensure uninterrupted operations during pandemics or sudden staff departures.

7.2 RD Department

7.2.1 Control Mapping and Justification

The following table maps selected Annex A controls to the RD department’s risks, as identified in the risk assessment.

Control (Annex A)	Justification	Status
A.5.1.1 Policies for Information Security	RD requires tailored information security policies to address specific asset and research data needs.	Included
A.5.18 Access Control Policy	Ensures RBAC is enforced across systems handling proprietary algorithms and IP.	Included
A.5.20 Authentication Information	MFA is implemented for all critical systems.	Included
A.5.28 Protection of Information in Transit	Required to protect sensitive research data transmitted between systems and collaborators.	Included
A.5.32 Logging	Supports forensic investigation in the event of insider threats.	Included
A.5.36 Backup	Regular backups of research and simulation environments are necessary to protect against corruption or loss.	Included
A.5.25 Cryptographic Controls	Ensures encryption of research databases and development repositories.	Included
A.5.10 Acceptable Use of Information	Not directly applicable to RD systems under strict access policies.	Excluded

7.3 Supply-Chain Assets

The supply chain assets focus on the organisation’s ERP-301 platform, which acts as a central procurement hub and integration point for dozens of external suppliers. Because a single weakness here can quickly propagate to production systems and disrupt service delivery, the associated controls are chosen both to mitigate the immediate threat and to harden the broader ecosystem. The table 7.2 maps each risk to its corresponding Appendix A control and explains why the control is either included or excluded.

Table 7.2: Statement of application for supply-chain assets

Asset ID	Threat	Control(s) (Annex A)	Justification for Inclusion/Exclusion
ERP-301	Supply-chain compromise (third-party)	A.15.1.1, A.15.2.1	Supplier vetting and continuous monitoring are mandatory.
ERP-301	Data-integrity loss (bad patch / config)	A.12.1.2, A.14.2.2	Formal change and update control essential.
ERP-301	System downtime (availability loss)	A.17.1.2, A.17.2.1	Backup and fail-over required for operational continuity.

The shared ERP-301 instance also drives procurement, making it the single integration point with numerous vendors. A lapse in supplier diligence could embed malware in firmware deliveries, so controls A.15.1.1 and A.15.2.1 enforce binding security clauses,

periodic assessments and service level triggers to detect anomalies early. Patch failures remain a major cause of ERP data corruption; segregated test environments and dual approval workflows (A.12.1.2, A.14.2.2) minimise the chance of bad updates reaching production. Finally, every minute of ERP downtime delays purchase orders and network maintenance spares, so hot standby infrastructure (A.17.1.2) and geographic replication (A.17.2.1) are essential to maintain supply chain resilience.

Appendix A

Asset Inventory

This appendix provides a consolidated view of GreenGrid Energy's inventory of critical assets, organised by department and mapped to the requirements of ISO/IEC 27001 Annex A 5.9.

To keep the register concise, we list each asset only once - using the system nomenclature introduced in section 1.4.4. Department-specific usage patterns and threat scenarios are then analysed in Chapter 6, where the same asset ID reappears with the vulnerabilities and threats relevant to each business unit. This two-step structure avoids duplication of effort, while still capturing the different risk profiles that result from how each department interacts with a shared system. Shared assets include the company-wide ERP instance, the central IT network stack, and services managed by HR and Customer Services.

Engineering & Grid Operations

Inventory #	ENG-001
Asset Name	SCADA System
Type	Software
Location	Substation A – Control Room
Internet Access	No
Essential	Yes
Asset Owner	Engineering & Grid Operations Manager
Maker / Model	Siemens SCADA v5
Serial & License	SCADA-9834
Support Contract	24×7
Confidentiality	4 (Medium)
Integrity	5 (High)
Availability	5 (High)
Criticality	High

Inventory #	ENG-002
Asset Name	Edge Computing Infrastructure
Type	Hardware
Location	Distributed across substations

Internet Access	Limited with VPN
Essential	Yes
Asset Owner	OT Security Engineer
Maker / Model	Dell Edge Gateway 5200
Serial & License	N/A
Support Contract	Standard Dell Support
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (High)
Criticality	High

Inventory #	ENG-003
Asset Name	OT Network Infrastructure
Type	Hardware
Location	Grid Operation Centres
Internet Access	No
Essential	Yes
Asset Owner	OT Security Engineer
Maker / Model	Palo Alto PA-5220, Cisco Industrial Switches
Serial & License	N/A
Support Contract	Vendor SLA
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (Critical)
Criticality	Critical

Research & Development

Inventory #	RD-101
Asset Name	Prototype Simulation Cluster 1
Type	Hardware/Software
Location	R&D Data Centre
Internet Access	No
Essential	Yes
Asset Owner	Director of R&D
Maker / Model	HP Apollo 6500 Gen10+
Serial & License	HPC-RD-7721
Support Contract	24×7 on-site (Hewlett-Packard)
Confidentiality	5 (High)
Integrity	5 (High)
Availability	4 (Medium)
Criticality	High

Inventory #	RD-102
Asset Name	Hybrid Cloud Platforms (AWS/Azure)
Type	Service (Infrastructure as a Service (IaaS)/Platform as a Service (PaaS))
Location	AWS (Ireland), Azure (Germany)
Internet Access	Yes with VPN and MFA
Essential	Yes
Asset Owner	Director of R&D
Maker / Model	AWS EC2, Azure Analytics
Serial & License	N/A
Support Contract	Cloud Provider SLA
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (High)
Criticality	High

Information Technology

Inventory #	IT-201
Asset Name	Microsoft 365 Environment
Type	Service
Location	Cloud
Internet Access	Yes
Essential	Yes
Asset Owner	CIO
Maker / Model	Exchange Online, Teams, SharePoint
Serial & License	N/A
Support Contract	MS Enterprise Agreement
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (High)
Criticality	High

Inventory #	IT-202
Asset Name	IT Network Infrastructure
Type	Hardware
Location	Central IT Data Centre
Internet Access	Controlled with VPN
Essential	Yes
Asset Owner	CISO
Maker / Model	Cisco ASA Firewall, Cisco Switches
Serial & License	N/A
Support Contract	Vendor SLA
Confidentiality	5 (High)

Integrity	5 (High)
Availability	5 (High)
Criticality	Critical

Supply Chain & Customer Services & Legal & Administration

Inventory #	ERP-301
Asset Name	SAP ERP System
Type	Software/Database
Location	Corporate DC / Cloud
Internet Access	VPN and MFA
Essential	Yes
Asset Owner	COO
Maker / Model	SAP S/4HANA 2022
Serial & License	SAP-GGE-4302
Support Contract	SAP Enterprise Support
Confidentiality	5 (Critical)
Integrity	5 (Critical)
Availability	5 (High)
Criticality	Critical

Inventory #	CS-401
Asset Name	CRM System
Type	Software/Database
Location	Azure Cloud
Internet Access	Yes but restricted
Essential	Yes
Asset Owner	Customer Services Manager
Maker / Model	Microsoft Dynamics 365
Serial & License	MS-CRM-GGE-5620
Support Contract	MS Enterprise Agreement
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (High)
Criticality	High

Human Resources

Inventory #	HR-501
Asset Name	Employee Management System
Type	Software/Database
Location	Corporate Data Centre
Internet Access	Internal only

Essential	Yes
Asset Owner	HR Director
Maker / Model	Oracle HCM Cloud 2023
Serial & License	ORA-HCM-GGE-7895
Support Contract	Oracle Premier Support
Confidentiality	5 (High)
Integrity	5 (High)
Availability	4 (Medium)
Criticality	High

Inventory #	HR-502
Asset Name	Employees
Type	Human Resources
Scope	All Departments - 400 employees
Essential	Yes
Asset Owner	Head of HR
Confidentiality	5 (High)
Integrity	5 (High)
Availability	5 (High)
Criticality	Critical

Bibliography

- [1] Advisera. All you need to know about setting the iso 27001 scope. <https://advisera.com/27001academy/knowledgebase/how-to-define-the-isms-scope/>, 2023. Accessed: 2024-03-10.
- [2] Gustavo De Felice. What is a risk matrix, how to prioritize risks in project management, 2024. Accessed: 2025-04-04.
- [3] ISMS.online. Iso/iec 27001 annex a controls. <https://www.isms.online/iso-27001/annex-a/>. Accessed: 2025-04-25.
- [4] ISO/IEC. Iso/iec 27001:2022 - information security management systems. <https://www.iso.org/standard/54534.html>, 2022. Accessed: 2024-03-10.
- [5] Portugal 2020. Portugal 2020 – European Structural and Investment Funds, 2020. Accessed: 2025-03-07.
- [6] High Table. Iso 27001 scope statement beginner's guide. <https://hightable.io/iso-27001-scope-statement/>, 2023. Accessed: 2024-03-10.